

Reflected XSS into HTML context with nothing encoded

Topic: Cross-Site Scripting (XSS) | Difficulty: Apprentice

Description

The search box reflects user-supplied input directly into the HTML response without encoding or sanitization. An attacker can craft a malicious URL containing a JavaScript payload which executes in the victim's browser when they click the link, enabling session theft, credential harvesting, and UI redressing attacks.

Steps to Exploit

1. Navigate to the product search functionality.
2. Enter a search term and observe the term reflected in the results page.
3. Intercept or modify the search request in Burp Suite.
4. Replace the search term with: `<script>alert(document.domain)</script>`
5. Send the request and observe the alert dialog firing.
6. Craft a malicious URL embedding the payload to distribute to victims.

Proof of Concept

Payload:

```
<script>alert(document.domain)</script>
```

Malicious URL:

```
/search?q=<script>alert(document.domain)</script>
```

Reflected in response:

```
<p>Search results for: <script>alert(document.domain)</script></p>
```

Impact

- Session token theft via document.cookie access.
- Phishing and credential harvesting by injecting fake login forms.
- Execution of arbitrary JavaScript in victim browsers.
- Defacement of the application as seen by targeted users.

Mitigation / Remediation

1. Encode all user-supplied output using context-appropriate encoding (HTML entity encoding).
2. Implement a strict Content Security Policy (CSP) to limit inline script execution.
3. Set the HttpOnly flag on session cookies to prevent JavaScript access.
4. Use a modern framework that auto-escapes template output by default.

CVSS Score

CVSS v3.1: 6.1 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

CVSS Justification

- Attack Vector: Network - delivered via crafted URL.
- Attack Complexity: Low - no special conditions required.
- Privileges Required: None.
- User Interaction: Required - victim must click the malicious link.
- Scope: Changed - JavaScript executes in victim's browser context.
- Confidentiality / Integrity: Low - session theft and DOM manipulation possible.